

Simulación de Auditoría SQL: GRANT y REVOKE



Escenario de Auditoría: Eres el responsable de seguridad de base de datos en la empresa *DataSur*. Tu tarea es auditar las sentencias de control de acceso ejecutadas en el servidor MySQL, corregir errores de sintaxis y ajustar los permisos según el **Principio de Menor Privilegio**.

Parte 1: Corrección de Sentencias Erróneas

El equipo técnico ejecutó las siguientes sentencias en la consola de administración. Identifica el error conceptual o de sintaxis y escribe la sentencia SQL corregida.

1. El administrador intentó revocar el permiso de inserción al usuario **Ana** sobre la tabla **ventas.pedidos**:

```
REMOVE INSERT ON ventas.pedidos TO 'ana'@'localhost';
```

Sentencia corregida:

2. Se intentó asignar permisos de lectura y actualización al usuario **Ana** sobre la tabla **ventas.pedidos**:

```
GRANT ON ventas.pedidos SELECT, UPDATE TO 'ana'@'localhost';
```

Sentencia corregida:

3. Se intentó auditar los permisos vigentes asignados a la cuenta **Ana**:

```
SHOW PRIVILEGES FOR 'ana'@'localhost';
```

Sentencia corregida:

4. Se intentó retirar todos los privilegios globales al usuario temporal **temp** usando una cláusula errónea:

```
REVOKE ALL PRIVILEGES ON . TO 'temp'@'localhost';
```

Sentencia corregida:

Parte 2: Validación y Aplicación del Principio de Menor Privilegio

Analiza cada caso laboral. Determina si los permisos actuales violan el principio de menor privilegio (sobrepermisos) o si impiden el trabajo del usuario, y redacta la sentencia SQL necesaria para normalizar la situación.

Usuario / Rol	Requerimiento del puesto	Estado actual de permisos
Ana (Ventas)	Consultar precios en ventas.precios y registrar pedidos en ventas.pedidos. No debe modificar precios ni borrar datos.	Tiene todos los privilegios sobre todas las tablas de ventas.
Carlos (Contabilidad)	Generar balances consultando contabilidad.balances y contabilidad.movimientos. No debe alterar datos.	Tiene SELECT, INSERT, UPDATE y DELETE sobre todas las tablas de contabilidad.
Lucía (Atención al Cliente)	Consultar datos de ventas.clientes y actualizar números de teléfono o direcciones. No debe borrar registros.	Tiene SELECT sobre ventas.clientes, pero no tiene UPDATE.

5. Caso Ana: Explica por qué sus permisos actuales son excesivos y escribe las sentencias SQL para revocar el exceso y asignarle únicamente SELECT en ventas.precios e INSERT en ventas.pedidos.

6. Caso Carlos: Identifica los permisos que le sobran y escribe la sentencia SQL para revocar INSERT, UPDATE y DELETE sobre todas las tablas de contabilidad, sin quitarle SELECT.

7. Caso Lucía: Indica qué permiso le falta para actualizar los datos de contacto y escribe la sentencia SQL para otorgarle únicamente UPDATE sobre ventas.clientes.
